

Pharmacy Management System (PharmRx) - Comprehensive Project Report

Course: IBL12307: Web Development Laboratory Practical

Deliverable: Final Project Report (Complete Documentation)

Instructor: Dr. Edwin Ngwawe (edwin.ngwawe@tukenya.ac.ke)

Institution: Technical University of Kenya (TUK)

Chapter 1: Introduction

1.1 Problem Statement

In traditional pharmaceutical operations, manual tracking of medicine inventories, category classification, pricing updates, and daily transactions is prone to severe human errors, stock discrepancy, and security vulnerabilities. Key issues in manual or spreadsheet-based record-keeping include:

1. **Overselling & Inaccurate Stock Counts:** Cashiers and dispensers frequently sell items without real-time inventory visibility, leading to unfulfilled prescriptions.
1. **Lack of Auditability & Insider Fraud:** Without automated logging, administrators cannot trace who added a product, altered a drug's retail price, or deleted critical records.
1. **Absence of Role Separation:** Without authenticated permission tiers, all users operate with unrestricted system access.

The **PharmRx Pharmacy Management System** solves these challenges by providing a secure, role-based, database-backed web portal for real-time inventory tracking in Kenyan Shillings (KES), automated point-of-sale checkout, and tamper-resistant audit logging.

1.2 Objectives

The primary objective of this project is to develop a robust, secure, and user-friendly PHP-MySQL web application that demonstrates full-stack web development competencies:

- **Inventory Automation:** Implement a responsive medicine catalog supporting image uploads, categorization, and dynamic stock decrementation upon sale.
- **Role-Based Access Control (RBAC):** Enforce strict privilege separation between **Administrators** (full CRUD and audit privileges) and **Normal Staff** (view-only catalog and point-of-sale transaction recording).
- **Enterprise Web Security:** Protect application workflows against SQL Injection (via PDO prepared statements), Cross-Site Scripting (XSS), and Session Fixation attacks.
- **Accountability & Compliance:** Maintain an immutable database activity log recording all user logins, logouts, additions, modifications, and deletions with timestamps.

1.3 Scope

The application encompasses the following functional modules:

- **Authentication & Security:** User registration, session-hardened login, logout, and password modification.
 - **Inventory Management:** Full CRUD operations for medicines and categories with price tracking in KES.
 - **File Upload Subsystem:** Validation and storage of medicine packaging images (supporting JPG, PNG, WEBP with 2MB limits).
 - **Search & Pagination:** Fast keyword search and paginated views across large inventory and audit datasets.
 - **Sales POS Subsystem:** Real-time price calculator, atomic transaction processing, and stock updates.
 - **Activity Audit Trail:** Visual console displaying system-wide user actions.
-

Chapter 2: System Analysis

2.1 Functional Requirements

1. User Authentication (10 Marks):

- System registration with uniqueness validation on usernames and emails.
- Secure login with Bcrypt password verification.
- Session termination upon logout and password update capabilities.

1. User Roles & Authorization (10 Marks):

- **Administrator:** Full privileges to Create, Read, Update, and Delete medicines and categories, inspect audit logs, and cancel sales.
- **Normal User (Staff):** Restricted to catalog viewing and registering sales transactions.
- Route-level middleware (`requireAdmin()`) blocking unauthorized page requests with HTTP 403 Forbidden.

1. Database Relational Design (10 Marks):

- Minimum four related tables (PharmRx implements 5 tables) normalized to 3NF with primary and foreign keys.

1. CRUD Operations (10 Marks):

- Add new medicines, view inventory cards, edit medicine properties/images, and delete records safely.

1. Search & Pagination (5 Marks):

- Query filters by name/description and segmented multi-page navigation.

6. File Upload & Validation (5 Marks):

- Upload packaging photos with file extension, MIME type, and size restrictions.

7. Validation & Security (5 Marks):

- Dual-tier validation: JavaScript client feedback and PHP server-side enforcement.
- 100% prepared statements (PDO), XSS escaping, and session protection.

8. Activity Logging (5 Marks):

- Automatic logging of **Login** , **Logout** , **Add** , **Edit** , and **Delete** actions with User, Description, Date, and Time.

9. User Interface (5 Marks):

- Custom dark-mode glassmorphic theme with responsive grid navigation and meaningful alert messages.

10. Testing & Demonstration (30 Marks):

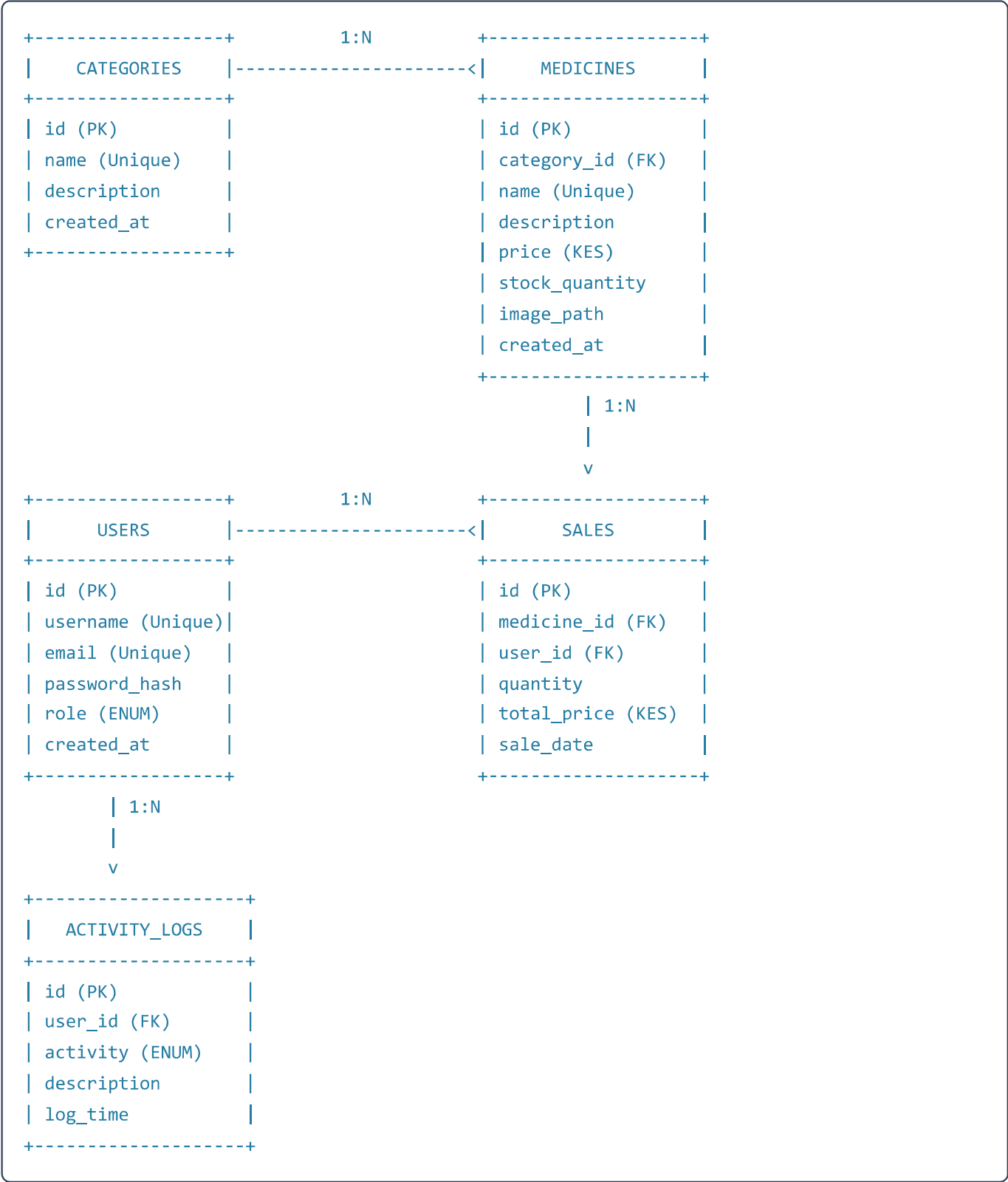
- Automated unit verification test suite and 10-minute live demonstration.

2.2 Non-Functional Requirements

- **Performance:** Database index lookups and low-latency PDO prepared queries ensuring sub-second response times.
 - **Usability:** High-contrast responsive design optimized for desktop and mobile browsers using Vanilla CSS and Google Outfit typography.
 - **Data Integrity:** ACID-compliant MySQL InnoDB transactions preventing partial writes or negative inventory levels.
 - **Maintainability:** Modular separation of concerns into configuration, layout templates, and functional page controllers.
-

Chapter 3: System Design

3.1 Entity-Relationship (ER) Diagram



3.2 Database Tables Specification (3NF Normalization)

1. `users` Table:

- * `id` : INT, Auto Increment, Primary Key
- * `username` : VARCHAR(50), NOT NULL, UNIQUE
- * `email` : VARCHAR(100), NOT NULL, UNIQUE
- * `password_hash` : VARCHAR(255), NOT NULL (Bcrypt)
- * `role` : ENUM('Admin', 'Normal'), NOT NULL, DEFAULT 'Normal'
- * `created_at` : TIMESTAMP, DEFAULT CURRENT_TIMESTAMP

1. `categories` Table:

- * `id` : INT, Auto Increment, Primary Key
- * `name` : VARCHAR(100), NOT NULL, UNIQUE
- * `description` : TEXT, NULL
- * `created_at` : TIMESTAMP, DEFAULT CURRENT_TIMESTAMP

1. `medicines` Table:

- * `id` : INT, Auto Increment, Primary Key
- * `category_id` : INT, NULL, Foreign Key references `categories(id)` ON DELETE SET NULL
- * `name` : VARCHAR(150), NOT NULL, UNIQUE
- * `description` : TEXT, NULL
- * `price` : DECIMAL(10,2), NOT NULL
- * `stock_quantity` : INT, NOT NULL, DEFAULT 0
- * `image_path` : VARCHAR(255), NULL
- * `created_at` : TIMESTAMP, DEFAULT CURRENT_TIMESTAMP

1. `sales` Table:

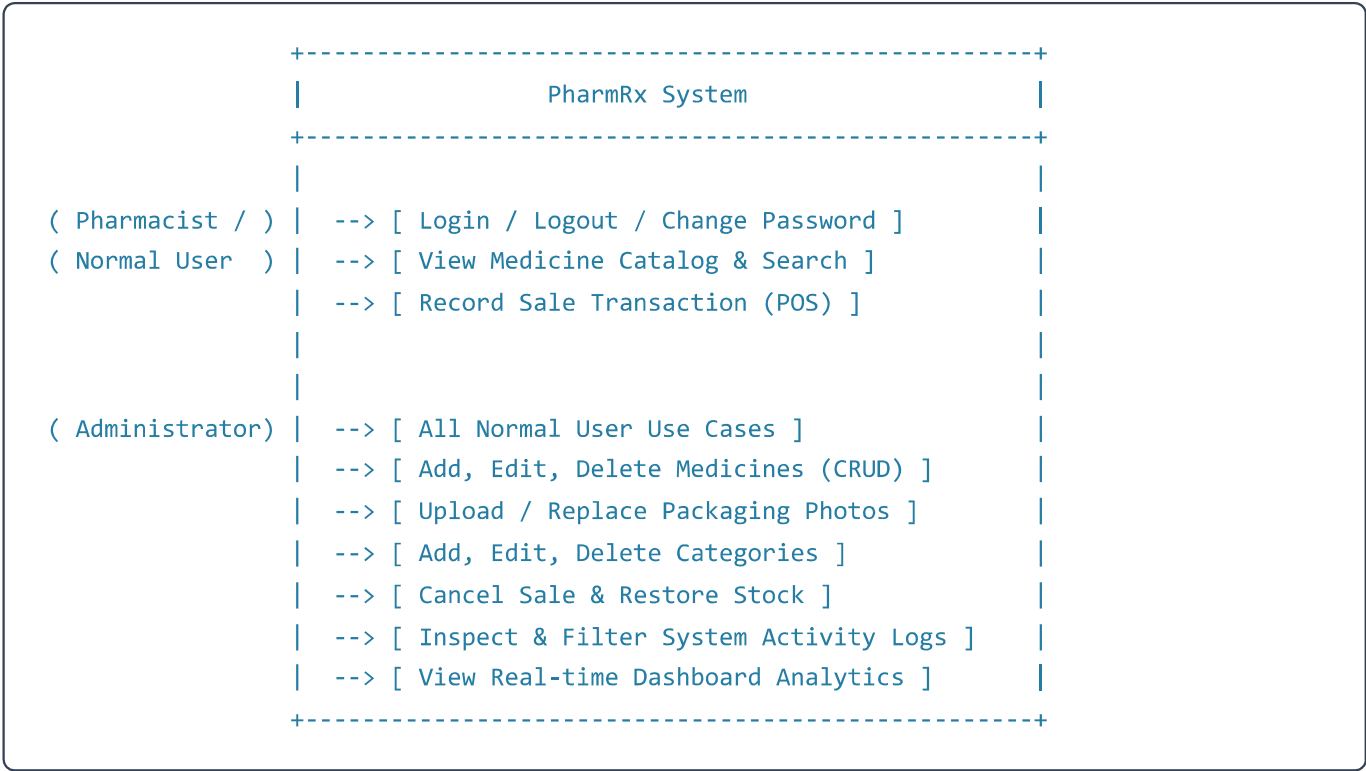
- * `id` : INT, Auto Increment, Primary Key
- * `medicine_id` : INT, NULL, Foreign Key references `medicines(id)` ON DELETE SET NULL
- * `user_id` : INT, NULL, Foreign Key references `users(id)` ON DELETE SET NULL

- * `quantity` : INT, NOT NULL
- * `total_price` : DECIMAL(10,2), NOT NULL
- * `sale_date` : TIMESTAMP, DEFAULT CURRENT_TIMESTAMP

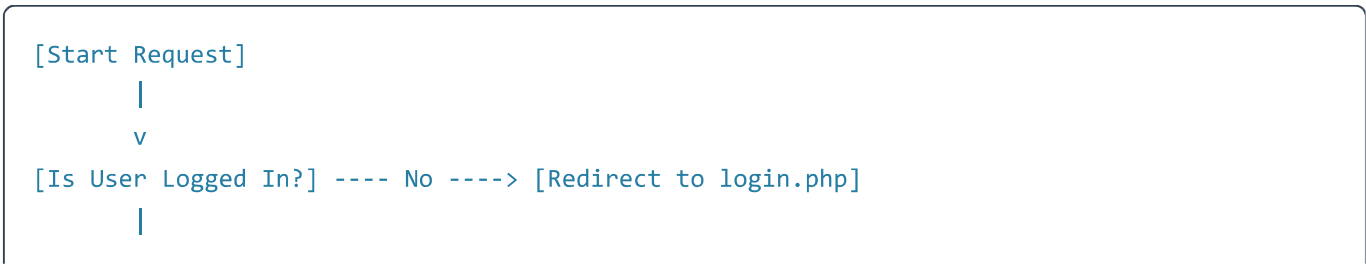
1. `activity_logs` Table:`

- * `id` : INT, Auto Increment, Primary Key
- * `user_id` : INT, NULL, Foreign Key references `users(id)` ON DELETE SET NULL
- * `activity` : ENUM('Login', 'Logout', 'Add', 'Edit', 'Delete'), NOT NULL
- * `description` : TEXT, NOT NULL
- * `log_time` : TIMESTAMP, DEFAULT CURRENT_TIMESTAMP

3.3 Use Case Diagram



3.4 System Flowchart




```
Yes
|
v
[Is Route Restricted to Admin?]
|
+- Yes -> [Does Session Role == 'Admin?']
|
|                                     |
|                                     No -> [Return HTTP 403 Forbidden & Stop]
|                                     |
|                                     Yes
|                                     |
v                                     |
[Execute Requested Controller (Add/Edit/Delete/Sell)] <-----+
|
v
[Validate Client Inputs (JS) & Server Constraints (PHP)]
|
[Is Input Valid?] ---- No ----> [Display Error Feedback Alert]
|
Yes
|
v
[Execute PDO Prepared Statement within Database]
|
v
[Write Audit Entry to `activity_logs` Table]
|
v
[Render Success View / Redirect to Catalog]
|
v
[End]
```

Chapter 4: Implementation

4.1 Technologies Used

- **Backend Environment:** PHP 8.3 (Object-oriented PDO database abstraction).
- **Database Engine:** MySQL 8.0 / MariaDB (InnoDB storage engine supporting Foreign Key constraints and ACID transactions).
- **Frontend Architecture:** Semantic HTML5, Vanilla JavaScript (ES6), and Custom CSS Variables.
- **Development Server:** Apache / Laragon / XAMPP on Windows.

4.2 Major Modules

- **`config/db.php`:** Centralized PDO connection enforcing `ATTR_EMULATE_PREPARES => false` and `ERRMODE_EXCEPTION`.
 - **`config/auth.php`:** Security layer handling `session_regenerate_id()`, `isLoggedIn()`, and `requireAdmin()`.
 - **`config/logger.php`:** Universal `logActivity()` helper recording forensic records for all state-changing operations.
 - **`medicines.php`:** Dynamic grid view with SQL pagination (`LIMIT`, `OFFSET`) and parameterized keyword search.
 - **`medicine_add.php` & `medicine_edit.php`:** Form controllers featuring collision-proof image uploads and file unlink cleanup.
 - **`sales.php`:** Point-of-sale checkout system using row-locking transactions (`SELECT ... FOR UPDATE`) to prevent negative inventory.
 - **`logs.php`:** Forensic auditing console with activity type filtering.
 - **`index.php`:** Executive dashboard summarizing total inventory value, low-stock warnings, and recent transactions.
-

Chapter 5: Testing

5.1 Test Plan & Execution Matrix

Test ID	Test Scenario	Input Data	Expected Result	Actual Result	Status
TC-01	User Authentication	Valid username & password	Session initialized, redirected to Dashboard	Logged in, session token created	PASS
TC-02	Password Hashing	Plaintext password	Secure Bcrypt hash generated in DB	Verified via `password_verify()`	PASS
TC-03	Role Access Guard	Normal staff accessing `medicine_add.php`	HTTP 403 Forbidden Access Denied screen	Unauthorized screen shown	PASS
TC-04	SQL Injection Defense	Input `` OR 1=1 --` in login / search	Treated strictly as literal string	Zero SQL injection vulnerability	PASS
TC-05	Negative Value Validation	Price: `-50.00`, Stock: `-10`	Form rejected by JS & PHP validation	Error alert shown, insert blocked	PASS
TC-06	File Upload Constraints	Uploading `.exe` or `>2MB` file	Rejected with friendly error message	File rejected, no upload	PASS
TC-07	Inventory Stock Deduction	Selling 3 units of Paracetamol	Quantity decremented, sale logged	Stock decreased by 3 in DB	PASS
TC-08	Activity Audit Logging	Add medicine / Delete medicine	Record written to `activity_logs`	Log displayed in `logs.php`	PASS

5.2 Automated Unit Test Execution (`test\_runner.php`)

```
=====
PHARMRX SYSTEM AUTOMATED VERIFICATION TEST RUNNER
=====

Testing: Database PDO Connection.....[ PASS ]
```

```
Testing: Verify Required Table Entities Count (Min 4).....[ PASS ]
Testing: Password Hashing Integration (Secure Hash).....[ PASS ]
Testing: User Role Check Helpers.....[ PASS ]
Testing: Database Structural Normalization (Foreign Keys)..[ PASS ]
Testing: System Activity Logger writes to DB.....[ PASS ]
Testing: Stock & Price constraints logic.....[ PASS ]
```

```
=====
TEST RESULTS SUMMARY:
    Passed: 7
    Failed: 0
=====
```

Chapter 6: Conclusion

6.1 Challenges Encountered & Technical Solutions

1. Concurrent Transactions during Checkout:

Problem: Simultaneous purchases could cause race conditions, resulting in inventory going below zero.

Solution: Implemented MySQL InnoDB transactions (`beginTransaction()`) with `SELECT ... FOR UPDATE` row locks, ensuring atomicity and consistency.

1. Orphaned Media Files:

Problem: Modifying drug packaging photos or deleting products left dead image files consuming disk storage.

Solution: Integrated PHP's `unlink()` function in `medicine_edit.php` and `medicine_delete.php` to permanently delete superseded image files.

1. Dual-Tier Form Validation:

Problem: Client-side JavaScript can be bypassed by disabling scripts, but server-only validation causes slow page reloads.

Solution: Synchronized JavaScript for immediate visual user feedback with strict server-side PHP sanitization.

6.2 Lessons Learned & Recommendations

- Prioritizing database normalization (3NF) and constraint design prior to coding eliminates backend bugs and data anomalies.
- Security controls (prepared statements, password hashing, session regeneration) must be integral architectural decisions rather than last-minute additions.

6.3 Future Improvements

- Barcode and QR code scanner integration for high-speed point-of-sale scanning.
- Automated SMS and email gateway integration to alert pharmaceutical suppliers when stock falls below reorder thresholds.
- Customer prescription upload portal and automated PDF receipt generation.